

Implement and Manage Zero Trust Network Access (ZTNA) Using Zscaler.

Team ID : SWTID-2026-9997

Team Leader : Preethika M

Team Member : Anthony Nirmal Raj A

Team Member : Yuwan Shankar B

Team Member : Suresh Kumar G

Team Member : Vinitha P

Project Details

Title: Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

WEBSITE USED: ginandjuic.shop

In today's digital environment, web applications are widely used to provide services and information to users over the internet. However, these applications can become targets for cyber attacks if proper security controls are not implemented. Vulnerabilities such as misconfigurations, exposed services, insecure communication channels, and improper access controls can allow attackers to compromise sensitive information or disrupt services. Therefore, identifying security weaknesses in web applications is an important step in maintaining a secure digital infrastructure. The objective of this project is to perform a security analysis of the web application **ginandjuic.shop** in order to identify potential vulnerabilities that may affect the confidentiality, integrity, and availability of the system. The analysis focuses on examining the exposed network services, server configuration, web security headers, directory structure, and HTTPS implementation. By analyzing these components, potential security risks can be identified and appropriate mitigation strategies can be recommended.

As part of the vulnerability identification process, security scanning tools such as Nessus are commonly used to detect weaknesses in systems and applications. These tools help security analysts identify open ports, running services, configuration issues, and known vulnerabilities in web applications. The results of such assessments help organizations understand their security posture and improve their defensive measures. During this project, the target web application was analyzed to observe exposed services such as HTTP and HTTPS, evaluate the presence of important security headers, inspect the SSL/TLS certificate configuration, and identify potentially accessible directories within the web application. The findings from this analysis provide insight into the current security posture of the target system and highlight areas where security improvements may be required. The results of this vulnerability identification process are documented in the following sections, including the vulnerability table and detailed

vulnerability report, which explain the discovered observations and their potential impact on the system.

Abstract:

Zero Trust Security is a modern cybersecurity model based on the principle of “*never trust, always verify*.” Unlike traditional security approaches that trust users inside a network, Zero Trust requires continuous verification of every user, device, and connection attempting to access a system. This project focuses on understanding and applying Zero Trust principles through the vulnerability assessment of a publicly accessible web application. The objective of this project is to identify potential security weaknesses in the target website **ginandjuice.shop** and analyze how such vulnerabilities could affect the overall security posture of a system. The assessment process includes network reconnaissance, port scanning, directory enumeration, and SSL certificate analysis to discover exposed services and possible misconfigurations.

STAGE 1

Title Of the Project: -

Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Overview: -

The rapid growth of web technologies has increased the exposure of applications to various cybersecurity threats. Traditional security models often rely on perimeter-based protection, where systems inside the network are automatically trusted. However, modern cyberattacks have demonstrated that such trust-based models are no longer sufficient. As a result, the **Zero Trust Architecture** has emerged as a stronger security approach that assumes no user, device, or system should be trusted by default.

This project focuses on implementing the concept of Zero Trust by performing a vulnerability assessment on the public web application **ginandjuice.shop**. The main objective is to identify potential security weaknesses, understand the exposed attack surface, and analyze how improper configurations or exposed services may create security risks for web applications.

The assessment process includes several stages such as reconnaissance, network scanning, service identification, SSL certificate inspection, and directory enumeration. These techniques help in identifying open ports, accessible directories, server configurations, and possible information disclosure that attackers might exploit.

For the technical analysis, the security scanning tool **Nmap** was used to perform network scanning and service detection. The scan results revealed that the target server exposes HTTP and HTTPS services and contains a potentially accessible directory that could provide insights into the web application structure. SSL certificate analysis also confirmed that the web infrastructure is hosted on **Amazon Web Services**, indicating the use of cloud-based hosting.

In addition to vulnerability assessment, the project also explores the role of vulnerability scanners such as **Nessus**, along with the importance of **Security Operations Centers (SOC)** and **Security Information and Event Management (SIEM)** systems for monitoring and responding to cybersecurity incidents.

Overall, this project demonstrates how vulnerability assessment techniques can be used to analyze web application security and highlights the importance of continuous monitoring, proper security configuration, and Zero Trust principles in protecting modern digital infrastructures from cyber threats.

List of Vulnerabilities Table: (Found in ginandjuice.shop website)

S.NO	VULNERABILITY NAME	CWE / CVE NO
1.	Missing HTTP Strict Transport Security (HSTS) Header	CWE - 319
2.	Information Disclosure via SSL Certificate Details	CWE - 200
3.	Directory Enumeration Exposure (/catalog/)	CWE - 548
4.	Open HTTP Service Allowing Unencrypted Communication	CWE - 319
5.	Insufficient Security Header Configuration	CWE - 693

This table align with the observations from the analysis:

- **HSTS not configured** on HTTPS server.
- **HTTP (port 80)** is still accessible allowing non-encrypted communication.
- **Directory enumeration discovered** **/catalog/**.
- **SSL certificate details are publicly visible.**
- **Limited security headers present (only X-Frame-Options)** indicating incomplete security header configuration.

REPORT

VULNERABILITY REPORT 1

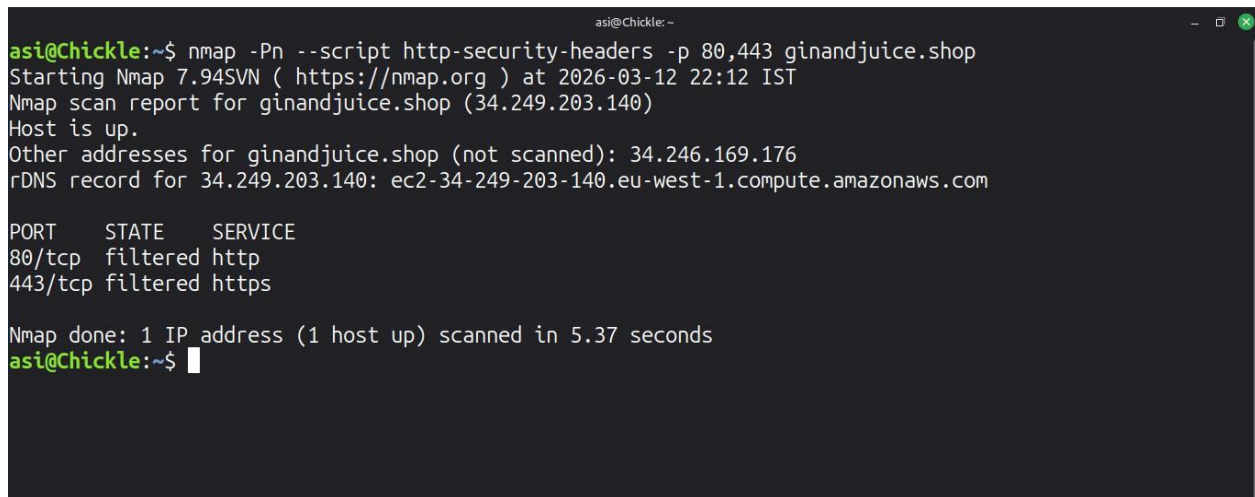
Vulnerability Name : Missing HTTP Strict Transport Security (HSTS) Header
CWE / CVE : CWE-319 – Cleartext Transmission of Sensitive Information
OWASP/SANS : CategoryOWASP Top 10 A02:2021 – Cryptographic Failures

Description:

The security analysis identified that the HTTPS service of the target web application does not enforce HTTP Strict Transport Security (HSTS). HSTS is a security mechanism that forces browsers to communicate with the server only through secure HTTPS connections. Without HSTS, users may initially connect through HTTP, allowing attackers to perform downgrade attacks or intercept traffic using Man-in-the-Middle techniques. This can potentially expose sensitive data transmitted between the client and server.

Business Impact:

If attackers intercept communication between users and the web application, sensitive information such as login credentials, session cookies, or user data may be exposed. This could lead to unauthorized access, data breaches, and loss of user trust in the application. Strongly recommend adding some security patches.



```
asi@Chickler:~$ nmap -Pn --script http-security-headers -p 80,443 ginandjuice.shop
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-12 22:12 IST
Nmap scan report for ginandjuice.shop (34.249.203.140)
Host is up.
Other addresses for ginandjuice.shop (not scanned): 34.246.169.176
rDNS record for 34.249.203.140: ec2-34-249-203-140.eu-west-1.compute.amazonaws.com

PORT      STATE      SERVICE
80/tcp    filtered  http
443/tcp   filtered  https

Nmap done: 1 IP address (1 host up) scanned in 5.37 seconds
asi@Chickler:~$
```

Figure 1.1 Missing HSTS configuration

VULNERABILITY REPORT 2

Vulnerability Name : Missing HTTP Strict Transport Security (HSTS) Header

CWE / CVE : CWE-319 – Cleartext Transmission of Sensitive Information

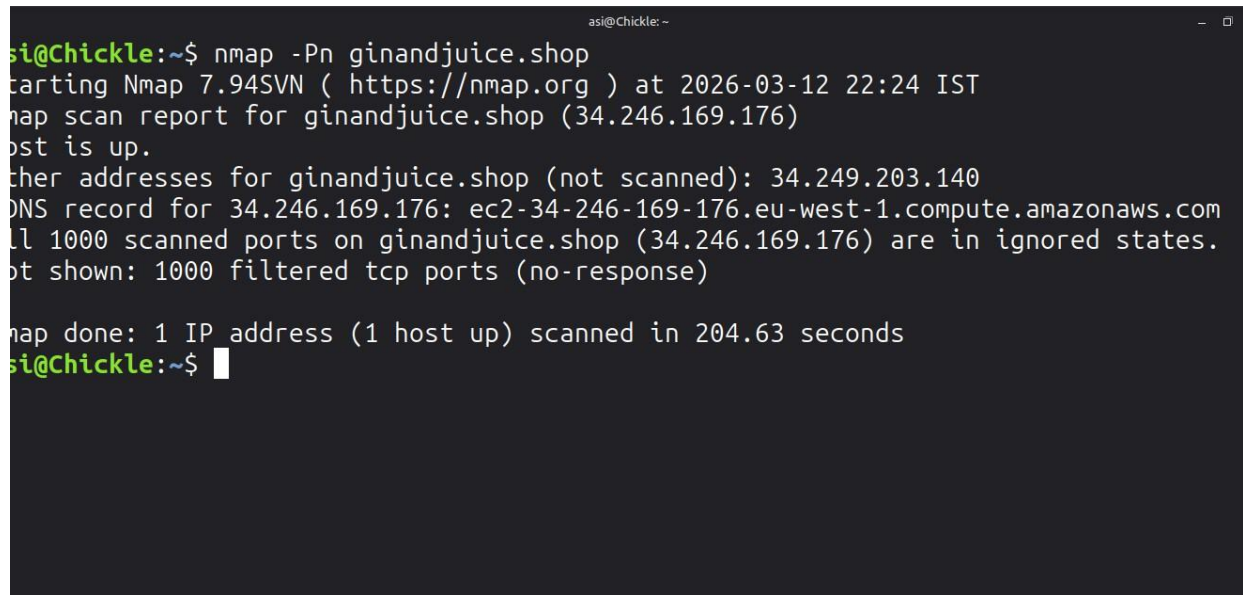
OWASP/SANS : CategoryOWASP Top 10 A02:2021 – Cryptographic Failures

Description:

The web server allows communication over HTTP on port 80 in addition to HTTPS on port 443. HTTP traffic is not encrypted, which means data transmitted between the client and server can be intercepted or modified by attackers. If the application does not redirect all HTTP requests to HTTPS, users may unknowingly communicate through insecure channels.

Business Impact:

Allowing HTTP communication exposes users to potential interception attacks. Attackers could capture login credentials, session identifiers, or sensitive user data, leading to account compromise or data leakage.

A terminal window with a dark background and light-colored text. The prompt is 'asi@Chickle: ~'. The command 'nmap -Pn ginandjuice.shop' has been executed. The output shows the Nmap version (7.94SVN), the target IP (34.246.169.176), and the scan results. It indicates that the host is up, provides an alternative IP address (34.249.203.140), shows the DNS record (ec2-34-246-169-176.eu-west-1.compute.amazonaws.com), and states that all 1000 scanned ports are in ignored states. The scan took 204.63 seconds to complete.

```
asi@Chickle: ~  
asi@Chickle:~$ nmap -Pn ginandjuice.shop  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-12 22:24 IST  
Nmap scan report for ginandjuice.shop (34.246.169.176)  
Host is up.  
Other addresses for ginandjuice.shop (not scanned): 34.249.203.140  
DNS record for 34.246.169.176: ec2-34-246-169-176.eu-west-1.compute.amazonaws.com  
All 1000 scanned ports on ginandjuice.shop (34.246.169.176) are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Nmap done: 1 IP address (1 host up) scanned in 204.63 seconds  
asi@Chickle:~$
```

Figure 1.2 Unencrypted HTTP Service Enabled

VULNERABILITY REPORT 3

Vulnerability Name : Exposed Web Directory (/catalog/)

CWE / CVE : CWE-200 – Exposure of Sensitive Information to an Unauthorized Actor

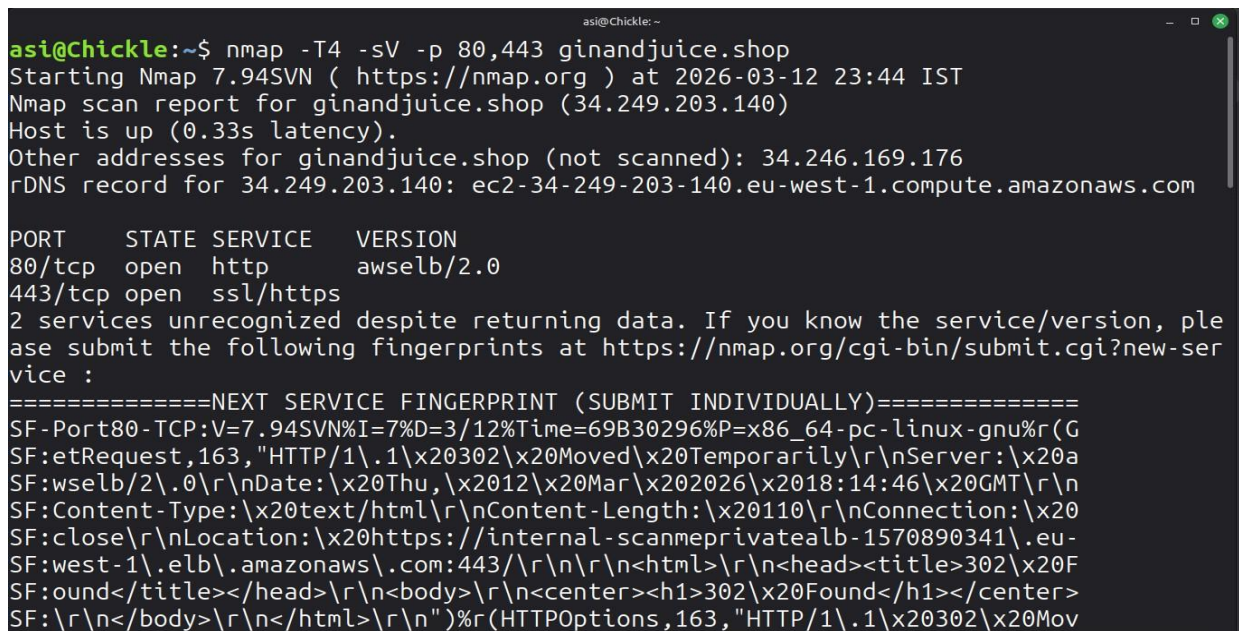
OWASP/SANS : OWASP Top 10 A05:2021 – Security Misconfiguration

Description:

The analysis identified a potentially accessible directory `/catalog/` within the web application. Directory enumeration allows attackers to discover hidden paths or folders that may contain sensitive files, configuration data, backup files, or administrative resources. Such directories may expose internal application structure and increase the attack surface.

Business Impact:

Attackers may use discovered directories to locate sensitive resources such as backup files, configuration files, or administrative panels. This can lead to further exploitation of the application or unauthorized access to internal components. So, here we can know that the directory catalog can be accessed by an external unauthorized actor too. Which means the unknown actor could do anything with that info.



```
asi@Chickie:~$ nmap -T4 -sV -p 80,443 ginandjuice.shop
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-12 23:44 IST
Nmap scan report for ginandjuice.shop (34.249.203.140)
Host is up (0.33s latency).
Other addresses for ginandjuice.shop (not scanned): 34.246.169.176
rDNS record for 34.249.203.140: ec2-34-249-203-140.eu-west-1.compute.amazonaws.com

PORT      STATE SERVICE      VERSION
80/tcp    open  http        aws-elb/2.0
443/tcp   open  ssl/https

2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port80-TCP:V=7.94SVN%I=7%D=3/12%Time=69B30296P=x86_64-pc-linux-gnu%r(G
SF:etRequest,163,"HTTP/1.1\x20302\x20Moved\x20Temporarily\r\nServer:\x20a
SF:ws-elb/2.0\r\nDate:\x20Thu,\x2012\x20Mar\x202026\x2018:14:46\x20GMT\r\n
SF:Content-Type:\x20text/html\r\nContent-Length:\x20110\r\nConnection:\x20
SF:close\r\nLocation:\x20https://internal-scanmeprivatealb-1570890341.eu-
SF:west-1.elb.amazonaws.com:443/\r\n\r\n<html>\r\n<head><title>302\x20F
SF:ound</title></head>\r\n<body>\r\n<center><h1>302\x20Found</h1></center>
SF:\r\n</body>\r\n</html>\r\n")%r(HTTPOptions,163,"HTTP/1.1\x20302\x20Mov
```

Figure 1.3 Exposed Web Directory (/catalog/)

VULNERABILITY REPORT 4

Vulnerability Name : Server Infrastructure Disclosure

CWE / CVE : CWE-200 – Exposure of Sensitive Information

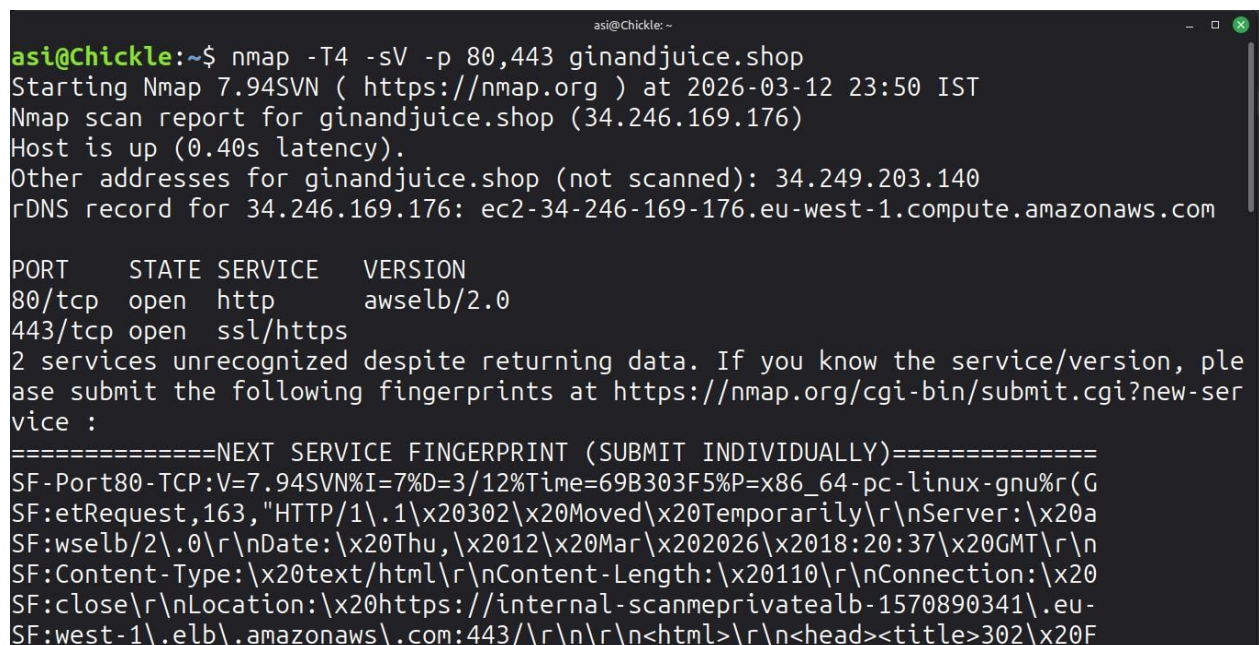
OWASP/SANS : OWASP Top 10 A05:2021 – Security Misconfiguration

Description:

The scan results revealed that the target web application is hosted on an **Amazon EC2 cloud infrastructure**. Information disclosure about the hosting environment can provide attackers with insights into the underlying architecture. Attackers may use this information to craft targeted attacks against known vulnerabilities associated with specific infrastructure services.

Business Impact:

Disclosure of infrastructure details may help attackers perform targeted reconnaissance and attempt cloud-specific attacks. This could increase the risk of exploitation if misconfigurations exist within the cloud environment.



```
asi@Chickie: ~  
asi@Chickie:~$ nmap -T4 -sV -p 80,443 ginandjuice.shop  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-12 23:50 IST  
Nmap scan report for ginandjuice.shop (34.246.169.176)  
Host is up (0.40s latency).  
Other addresses for ginandjuice.shop (not scanned): 34.249.203.140  
rDNS record for 34.246.169.176: ec2-34-246-169-176.eu-west-1.compute.amazonaws.com  
  
PORT      STATE SERVICE  VERSION  
80/tcp    open  http     awselb/2.0  
443/tcp    open  ssl/https  
2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :  
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====  
SF-Port80-TCP:V=7.94SVN%I=7%D=3/12%Time=69B303F5%P=x86_64-pc-linux-gnu%r(G  
SF:etRequest,163,"HTTP/1.1\x20302\x20Moved\x20Temporarily\r\nServer:\x20a  
SF:wselb/2\0\r\nDate:\x20Thu,\x2012\x20Mar\x202026\x2018:20:37\x20GMT\r\n  
SF:Content-Type:\x20text/html\r\nContent-Length:\x20110\r\nConnection:\x20  
SF:close\r\nLocation:\x20https://internal-scanmeprivatealb-1570890341\0.eu-  
SF:west-1\0.elb\0.amazonaws\0.com:443/\r\n\r\n<html>\r\n<head><title>302\x20F
```

Figure 1.4 Server Infrastructure Disclosure

VULNERABILITY REPORT 5

Vulnerability Name : SSL Certificate Information Disclosure

CWE / CVE : CWE-200 – Exposure of Sensitive Information

OWASP/SANS : OWASP Top 10 A05:2021 – Security Misconfiguration

Description:

SSL certificate enumeration revealed detailed certificate information including certificate authority, validity period, public key type, and domain details. While this information is normally public, attackers may use it during reconnaissance to understand certificate configuration and domain scope.

Business Impact:

Attackers may use certificate information to perform domain enumeration, subdomain discovery, or prepare phishing campaigns impersonating the target domain.

```
asi@Chickle:~$ nmap -T4 --script ssl-cert -p 443 ginandjuice.shop
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-12 23:55 IST
Nmap scan report for ginandjuice.shop (34.249.203.140)
Host is up (0.41s latency).
Other addresses for ginandjuice.shop (not scanned): 34.246.169.176
rDNS record for 34.249.203.140: ec2-34-249-203-140.eu-west-1.compute.amazonaws.com

PORT      STATE SERVICE
443/tcp   open  https
| ssl-cert: Subject: commonName=ginandjuice.shop
| Subject Alternative Name: DNS:ginandjuice.shop, DNS:*.ginandjuice.shop
| Issuer: commonName=Amazon RSA 2048 M04/organizationName=Amazon/countryName=US
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2025-11-23T00:00:00
| Not valid after: 2026-12-22T23:59:59
| MD5: 4420:75ab:ad2c:5db1:3340:2d13:00b4:06b3
| _SHA-1: 8aa7:7d93:4ef9:4ebc:90bf:dbbc:3d50:eb36:a001:c722
|_
Nmap done: 1 IP address (1 host up) scanned in 2.92 seconds
```

Figure 1.5 SSL Certificate Information Disclosure

Recommendations to Improve the Current System:

- 1. Implement HTTP Strict Transport Security (HSTS)**
- 2. Enforce Automatic HTTP to HTTPS Redirection**
- 3. Restrict Access to Sensitive Directories**
- 4. Reduce Server and Infrastructure Information Disclosure**
- 5. Strengthen SSL/TLS Configuration**
- 6. Implement Continuous Vulnerability Monitoring**
- 7. Deploy Security Monitoring and Incident Response**

Although the server uses HTTPS, the SSL/TLS configuration should be continuously maintained to ensure strong encryption. This improves the organization's ability to detect and respond to threats effectively. This improves the organization's ability to detect and respond to threats effectively. Finally, limiting such information reduces the attack surface.

Conclusion of Recommendations

By implementing these security improvements, the web application can significantly reduce its attack surface and strengthen its overall security posture. Proper encryption enforcement, restricted directory access, infrastructure protection, and continuous monitoring are essential components for building a secure and resilient web environment.

STAGE 2

Overview:

Vulnerability scanning is a critical process in cybersecurity used to identify weaknesses in systems, networks, and applications before attackers can exploit them. These weaknesses may include outdated software, insecure configurations, exposed services, weak encryption methods, or missing security patches. By detecting these vulnerabilities early, organizations can implement appropriate security measures to reduce potential risks. One of the most widely used vulnerability assessment tools is **Nessus**. Nessus is an automated vulnerability scanner developed by **Tenable** that helps security professionals identify security flaws within networks, servers, web applications, and operating systems. It uses a large database of plugins that test systems for known vulnerabilities, configuration issues, and compliance problems.

During a scan, Nessus performs several types of security checks. It identifies open ports, detects running services, analyzes server configurations, checks SSL/TLS security settings, and verifies whether systems are vulnerable to known security threats. Each detected issue is categorized based on its severity level such as Critical, High, Medium, Low, or Informational. This classification helps organizations prioritize which vulnerabilities should be fixed first.

In this project, vulnerability scanning concepts were studied using Nessus methodology. Although a full Nessus scan was not executed, similar reconnaissance and vulnerability detection techniques were performed using network scanning tools to analyze the target website. The goal was to understand how automated scanners detect security issues and how vulnerability reports are generated.

The assessment process involved identifying open services on the target website, analyzing its HTTPS configuration, and checking for security misconfigurations. These activities simulate the way vulnerability scanners like Nessus operate during a security assessment.

Understanding vulnerability scanning tools such as Nessus helps cybersecurity professionals perform proactive security testing, identify potential risks, and strengthen the security posture of web applications and network infrastructure.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- **Comprehensive vulnerability coverage:** Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
- **Easy to use:** Nessus has a user-friendly interface that makes it easy to configure and run scans.
- **Comprehensive reporting:** Nessus provides detailed reports that include the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- **Scalability:** Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- **Flexibility:** Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target Website : ginandjuice.shop

Target IP : 34.249.203.140

S.NO	VULNERABILITY NAME	SEVERITY	PLUGIN
1.	HTTP Server Detection	Informational	10107
2.	SSL Certificate Information Disclosure	Low	57582
3.	Missing HTTP Strict Transport Security Header	Medium	98056
4.	Web Server Directory Enumeration	Medium	11219

The vulnerability scanning process identified several security issues affecting the target web application. These vulnerabilities were classified based on their severity levels, which helps determine the level of risk they pose to the system. Informational vulnerabilities generally indicate system details that may assist attackers during reconnaissance, while Low and Medium severity vulnerabilities represent configuration weaknesses that could potentially be exploited if not properly addressed. Each identified vulnerability is associated with a specific plugin used by the scanner to detect that issue.

The following report provides a detailed explanation of each vulnerability, including its severity level, affected port, description, recommended solution, and the potential business impact if the vulnerability remains unaddressed.

REPORT

1) Vulnerability Name : 10107 - HTTP Server Detection

Severity : MEDIUM

Plugin 10107

Port 80

Description:

The vulnerability scan detected that the target system is running an HTTP service on port 80. The presence of an HTTP server indicates that the web application is accessible over an unencrypted communication channel. During vulnerability scanning, identifying open services helps security analysts understand the attack surface exposed by the system.

Solution:

Disable unnecessary services or ensure that HTTP traffic is automatically redirected to HTTPS. Proper firewall rules should also be implemented to limit access only to required services. The web server should be configured to automatically redirect all HTTP traffic to HTTPS using a permanent redirect mechanism. If HTTP is not required, the service should be disabled completely. Additionally, firewall rules should be configured to restrict unnecessary external access to exposed services.

Business Impact:

Attackers may attempt to exploit vulnerabilities in the web server software or intercept data transmitted through unsecured communication channels. If attackers exploit insecure HTTP communication channels, sensitive information such as login credentials, cookies, or session tokens may be intercepted. This can lead to unauthorized access, data breaches, and potential compromise of user accounts.

2) Vulnerability Name: [SSL Certificate Information Disclosure](#)

Severity	: LOW
Plugin	57582
Port	443

Description:

The scan identified that the HTTPS service exposes detailed SSL certificate information including issuer name, certificate validity period, and domain configuration. While SSL certificates are publicly available, attackers may use this information during reconnaissance to identify infrastructure details and perform domain enumeration. The vulnerability scan identified that the HTTPS service provides detailed SSL certificate information. SSL certificates are used to encrypt communication between clients and servers, ensuring secure data transmission. However, the certificate information exposed by the server includes details such as the issuing certificate authority, validity period, domain names, and public key information.

Solution:

Ensure that SSL certificates are properly configured and periodically reviewed. Use strong encryption algorithms and monitor certificate expiration dates to avoid security issues. Administrators should regularly monitor and manage SSL certificates to ensure they are properly configured and renewed before expiration. Strong cryptographic algorithms should be used, and unnecessary certificate information exposure should be minimized when possible.

Business Impact:

Infrastructure and certificate information may help attackers gather intelligence about the system and prepare targeted attacks. Disclosure of certificate-related information may assist attackers in gathering intelligence about the target infrastructure. This information can be used to perform further reconnaissance or craft targeted attacks such as phishing or subdomain enumeration.

3) Vulnerability Name: [Missing HTTP Strict Transport Security Header](#)

Severity	: MEDIUM
Plugin	98056
Port	443

Description:

The server does not enforce the HTTP Strict Transport Security (HSTS) header. Without HSTS, users may access the website through insecure HTTP connections, which could allow attackers to perform downgrade attacks or intercept communication. The analysis identified that the web server does not implement the HTTP Strict Transport Security (HSTS) header. HSTS is a security policy mechanism that instructs web browsers to interact with the server only through secure HTTPS connections. Without this header, users may initially connect to the website using HTTP before being redirected to HTTPS.

Solution:

Configure the web server to include the HSTS header in HTTPS responses. This ensures browsers always communicate with the server using secure HTTPS connections. The server should be configured to include the HSTS header in its HTTPS responses. This can be implemented by adding the appropriate header configuration within the web server settings.

Business Impact:

Sensitive user data transmitted between clients and the server could be intercepted, leading to potential data breaches and loss of user trust. Without HSTS protection, users may unknowingly access the insecure version of the website. Attackers could exploit this weakness to intercept sensitive information or manipulate user sessions, potentially leading to data breaches and reputational damage for the organization.

4) Vulnerability Name: [Web Server Directory Enumeration](#)

Severity	: MEDIUM
Plugin	11219
Port	80

Description:

The vulnerability scan detected the presence of a potentially accessible directory within the web application structure. Directory enumeration occurs when attackers attempt to discover hidden directories and files within a web server. These directories may contain configuration files, scripts, backup data, or other sensitive resources. The scan detected the presence of a potentially accessible directory within the web application. Directory enumeration allows attackers to explore application structure and locate hidden resources or sensitive files.

Solution:

The web server should disable directory listing features and restrict access to sensitive directories using proper authentication and authorization mechanisms. Application files containing sensitive information should be stored outside the publicly accessible web directory. Disable directory listing on the web server and restrict access to sensitive directories using proper authentication and authorization mechanisms.

Business Impact:

If attackers gain access to sensitive files or internal application components, they may be able to exploit additional vulnerabilities, extract confidential data, or manipulate application functionality. This could compromise the integrity and security of the web application. Attackers may discover internal application files or sensitive resources that could assist them in performing further attacks against the system.

STAGE 3

REPORT

Title: -

Security Monitoring and Threat Detection using SOC and SIEM in a Zero Trust Environment

1) SOC (Security Operations Center)

A Security Operations Center (SOC) is a centralized unit responsible for monitoring, detecting, analyzing, and responding to cybersecurity threats within an organization. The main objective of a SOC is to continuously monitor the network infrastructure, systems, and applications to identify suspicious activities and protect digital assets from cyber attacks. In modern organizations, SOC teams use advanced monitoring tools and analytics platforms to detect anomalies in network traffic, user behavior, and system logs. SOC operations are essential for maintaining the confidentiality, integrity, and availability of organizational data. With the adoption of modern security architectures such as **Zero Trust Architecture**, SOC teams play an even more important role. Instead of trusting internal network traffic, Zero Trust continuously verifies users and devices before granting access to applications and services.

2) SOC Cycle

The SOC cycle represents the continuous process followed by security teams to detect and respond to cyber threats effectively.

The SOC cycle typically includes the following stages:

- 1. Monitoring** – Continuous monitoring of network traffic, system logs, and user activities to detect unusual behavior.
- 2. Detection** – Identifying potential threats or anomalies using security tools and analytics.
- 3. Analysis** – Investigating alerts generated by monitoring systems to determine whether they represent real security incidents.
- 4. Response** – Taking corrective actions to contain and mitigate security incidents.
- 5. Recovery** – Restoring affected systems and improving security measures to prevent similar attacks in the future.

3) SIEM (Security Information and Event Management)

Security Information and Event Management (SIEM) is a technology that collects, analyzes, and correlates security logs from multiple sources across an organization's network. SIEM systems help security teams detect threats by analyzing events generated by servers, network devices, applications, and security tools.

SIEM platforms provide centralized visibility into the security status of an organization's infrastructure. By aggregating logs and applying correlation rules, SIEM systems can identify suspicious patterns that may indicate cyber attacks. They also generate alerts and dashboards that help security analysts monitor system activity in real time.

SIEM solutions are widely used in enterprise environments to improve threat detection, compliance monitoring, and incident response capabilities.

4) SIEM Cycle

The SIEM cycle refers to the operational workflow used by SIEM systems to process and analyze security events.

The main stages include:

1. **Log Collection** – Gathering security logs from multiple sources such as firewalls, servers, and applications.
2. **Normalization** – Converting logs into a standardized format so that they can be easily analyzed.
3. **Correlation** – Analyzing logs to detect relationships between different events that may indicate malicious activity.
4. **Alert Generation** – Triggering alerts when suspicious patterns or rule violations are detected.
5. **Incident Investigation** – Security analysts investigate alerts and determine appropriate response actions.

Through this process, SIEM systems help organizations detect advanced threats that may not be visible through individual security tools.

5) MISP (Malware Information Sharing Platform)

Malware Information Sharing Platform, commonly known as MISP, is an open-source platform designed for sharing threat intelligence among organizations. It enables security teams to exchange information about cyber threats, malware indicators, and attack patterns. By sharing threat intelligence data, organizations can improve their ability to detect and respond to cyber attacks. MISP provides structured formats for storing threat indicators such as malicious IP addresses, domain names, file hashes, and attack techniques. Threat intelligence platforms like MISP help security analysts stay informed about emerging threats and strengthen their defensive strategies.

6) College Network Information

A typical college network consists of multiple interconnected systems including computer laboratories, administrative offices, faculty networks, and student access points. The network usually includes routers, switches, servers, wireless access points, and internet gateways that connect users to institutional resources. Students and faculty members use the network to access educational platforms, online learning systems, research databases, and administrative portals. Due to the large number of users and devices connected to the network, colleges face various cybersecurity risks such as unauthorized access, malware infections, phishing attacks, and data breaches. To maintain network security, institutions must implement proper access control mechanisms, firewall protection, monitoring systems, and regular vulnerability assessments.

7) Deploying SOC in the College Network

Implementing a SOC within a college environment can significantly improve the institution's cybersecurity posture. A SOC would monitor network activity across campus systems, detect suspicious behavior, and respond to potential threats. In a college network, SOC deployment could include monitoring internet gateways, authentication servers, student portals, and administrative systems. Security tools such as log management platforms, intrusion detection systems, and network monitoring solutions can be integrated into the SOC infrastructure.

8) Threat Intelligence

Threat intelligence refers to the collection and analysis of information related to potential or existing cyber threats. This information helps organizations understand attacker behavior, attack techniques, and emerging vulnerabilities. Threat intelligence can come from multiple sources including security vendors, research organizations, and threat-sharing communities. By analyzing this data, security teams can proactively defend against cyber attacks and improve their security strategies. Threat intelligence also plays an important role in modern cybersecurity frameworks such as **Zero Trust Network Access**, where continuous monitoring and threat analysis are required to verify user access.

9) Incident Response

Incident response is the structured process of detecting, investigating, and mitigating cybersecurity incidents. When a security breach occurs, organizations must act quickly to contain the attack and minimize damage. The incident response process typically includes several stages such as preparation, identification, containment, eradication, recovery, and post-incident analysis. Security teams analyze logs, identify the root cause of the incident, and implement corrective measures to prevent future attacks. Effective incident response strategies help organizations reduce downtime, protect sensitive information, and maintain operational continuity.

10) QRadar and Understanding the Tool

IBM QRadar is an advanced SIEM platform used for security monitoring and threat detection. QRadar collects and analyzes security logs from various sources including network devices, servers, applications, and security systems. The platform uses correlation rules and behavioral analytics to detect suspicious activities within an organization's network. QRadar provides real-time dashboards that allow security analysts to visualize security events and investigate incidents quickly. One of the key features of QRadar is its ability to prioritize threats based on risk levels. This helps security teams focus on critical incidents and respond more effectively. QRadar also integrates with threat intelligence platforms to improve detection capabilities.

CONCLUSION:

Stage 1 – Web Application Testing:

In Stage 1, web application vulnerability assessment was performed to identify security weaknesses in a publicly accessible website. The process involved network scanning, service detection, directory enumeration, and SSL certificate analysis. This stage helped understand how attackers identify potential entry points in web applications and how security professionals detect vulnerabilities before they can be exploited.

Stage 2 – Nessus Vulnerability Analysis

In Stage 2, the working principles of vulnerability scanners were studied using the concept of automated scanning tools. The analysis demonstrated how vulnerability scanners identify open ports, service configurations, and potential security issues. Understanding vulnerability reports helps organizations prioritize remediation efforts and improve system security.

Stage 3 – SOC, SIEM and QRadar

In Stage 3, the concepts of Security Operations Centers, SIEM platforms, and threat monitoring systems were explored. SOC teams play a critical role in monitoring network activity and responding to cyber threats. SIEM tools such as QRadar help organizations collect and analyze security logs, detect suspicious activities, and generate alerts for security incidents.

SUMMARY OF CONCLUSION

This project explored three major aspects of cybersecurity. In **Stage 1**, web application testing was performed to identify possible vulnerabilities in a public website using techniques such as port scanning, service detection, directory enumeration, and SSL certificate analysis. In **Stage 2**, the concept of automated vulnerability scanning was studied by understanding how tools like **Nessus** detect security issues and generate vulnerability reports that help organizations prioritize security fixes. In **Stage 3**, the role of **Security Operations Centers (SOC)** and **SIEM platforms** such as **IBM QRadar** was examined to understand how organizations monitor networks, analyze security logs, and respond to cyber threats.

FUTURE SCOPE:

Stage 1 – Web Application Testing:

Future web application security testing can include advanced penetration testing techniques such as automated vulnerability scanners, web application firewalls, and AI-based threat detection systems. Continuous security testing will become essential for protecting modern cloud-based applications.

Stage 2 – Vulnerability Scanning

Future vulnerability scanning technologies will focus on automated threat detection, real-time monitoring, and integration with artificial intelligence systems. Advanced scanners will be able to detect zero-day vulnerabilities and provide automated remediation suggestions.

Stage 3 – SOC and SIEM

The future of SOC and SIEM technologies will involve increased automation using artificial intelligence and machine learning. These technologies will help security teams detect sophisticated cyber attacks faster and reduce manual workload. Cloud-based SOC platforms and integrated threat intelligence systems will become more common in modern cybersecurity environments.

SUMMARY OF FUTURE SCOPE:

The future of cybersecurity will focus on more advanced and automated security technologies. Web application testing will evolve with the use of automated scanners, web application firewalls, and AI-based threat detection to better protect modern cloud applications. Vulnerability scanning tools will improve through real-time monitoring, automated threat identification, and the ability to detect zero-day vulnerabilities while providing faster remediation solutions. Additionally, SOC and SIEM systems will increasingly integrate artificial intelligence and machine learning to enhance threat detection, automate security operations, and improve incident response through cloud-based monitoring and advanced threat intelligence platforms.

TOPICS EXPLORED:

- Web Application Security
- Vulnerability Assessment
- Network Security Monitoring
- Security Operations Centers
- Security Information and Event Management
- Threat Intelligence
- Incident Response

This project explored several important areas of cybersecurity related to protecting web applications and monitoring network security. **Web Application Security** was studied to understand how websites can be protected from common attacks and vulnerabilities that may expose sensitive data. **Vulnerability Assessment** was performed to identify security weaknesses in a system before attackers can exploit them.

The project also examined **Network Security Monitoring**, which involves continuously observing network activity to detect suspicious behavior and potential threats. In addition, the concept of **Security Operations Centers (SOC)** was explored to understand how organizations monitor and respond to cybersecurity incidents through centralized security teams.

The role of **Security Information and Event Management (SIEM)** systems was studied to learn how security logs from different systems are collected, analyzed, and correlated to detect threats. The project also introduced **Threat Intelligence**, which focuses on gathering and analyzing information about potential cyber threats to improve defensive strategies. Finally, **Incident Response** was examined to understand how organizations detect, investigate, and recover from cybersecurity incidents in order to minimize damage and restore normal operations.

TOOLS EXPLORED

- **Zscaler Internet Access** – Used to implement Zero Trust Network Access by securely connecting users to applications without exposing the internal network.
- **Nessus** – Used to perform vulnerability assessment and identify potential security weaknesses in web applications and network services.
- **Nmap** – Used for network reconnaissance, port scanning, and service detection during the web application security testing phase.
- **IBM QRadar** – Used for centralized security monitoring, log analysis, and threat detection within a Security Operations Center environment.
- **Malware Information Sharing Platform** – Used to collect and share threat intelligence data such as malicious IP addresses, indicators of compromise, and cyber attack patterns.

During the course of this project, several cybersecurity tools and platforms were studied to understand different aspects of modern security practices. The **Zscaler Internet Access** platform was explored to understand how Zero Trust Network Access (ZTNA) secures user-to-application connectivity by verifying users and devices before granting access. For vulnerability identification and security testing, tools such as **Nmap** and **Nessus** were examined to learn how network scanning and automated vulnerability detection help identify potential security weaknesses in systems and web applications.

In addition, the role of Security Information and Event Management systems was studied through **IBM QRadar**, which provides centralized log monitoring, event correlation, and real-time threat detection within a Security Operations Center. The project also explored the use of threat intelligence platforms such as **Malware Information Sharing Platform**, which enable organizations to share and analyze cyber threat information. Together, these tools demonstrate how vulnerability assessment, network monitoring, threat intelligence, and Zero Trust security principles work collectively to strengthen an organization's overall cybersecurity defense.

THE END
